

PRESENTATION FINALE PROJET CYBER SECURISATION DES INFRAS

1. Barème d'évaluation – Projet « Sécurisation serveur web & BDD – Défense en profondeur »

Note finale sur 30 – Note de groupe

A. Architecture & conception globale (3 points)

Critère	Attentes
Segmentation réseau	4 réseaux distincts clairement identifiés : DMZ, Frontend, Data, Admin
Justification des zones	Rôle de chaque réseau expliqué (menace, exposition, confiance)
Défense en profondeur	Cohérence globale des couches (réseau, système, service)
Documentation	Schéma réseau clair (flux, IP, rôles)

B. Réseau & firewall pfSense (2 points)

Critère	Attentes
Routage inter-réseaux Politique de filtrage	pfSense unique point de passage entre zones Principe du deny by default , règles explicites
Flux applicatifs	Flux strictement nécessaires ouverts (HAProxy → Web → BDD)
NAT & exposition	VIP HAProxy NATée vers WAN, aucune autre machine exposée
Réseau admin	Accès d'administration isolé, non accessible depuis DMZ

C. Haute disponibilité & HAProxy (2 points)

Critère	Attentes
Redondance	2 HAProxy fonctionnels
VIP	VIP partagée (VRRP / keepalived ou équivalent)
Résilience	Bascule démontrable en cas de panne

D. Sécurisation systèmes (AlmaLinux + CIS) (3 points)

Critère	Attentes
CIS Level 1	Mesures pertinentes appliquées et comprises
Services	Services inutiles désactivés
Accès SSH	Accès sécurisé (clé, restrictions, réseau admin)
Journalisation	Logs actifs et exploitables

E. Base de données & application (2 points)

Critère	Attentes
Isolation BDD	BDD accessible uniquement depuis le serveur web
Sécurité	Comptes, permissions, port, écoute réseau contrôlés

F. Présentation Powerpoint (8 point)

Critère	Attentes
Lisibilité et clarté	Police lisible, couleurs contrastées, slides pas surchargées, informations essentielles visibles immédiatement
Organisation et structure	Slides dans un ordre logique (intro → architecture → sécurité → démo → conclusion), plan/sommaire clair, transitions compréhensibles
Contenu technique adapté	Schémas réseau, flux, services et mesures de sécurité correctement représentés, informations pertinentes pour L2
Illustrations et visuels	Schémas, diagrammes, captures d'écran ou icônes qui clarifient le discours, pas d'images inutiles

Qualité générale / esthétique	Diaporama harmonieux, cohérence visuelle, orthographe correcte, support agréable à suivre
--------------------------------------	---

? G. Questions / réponses (10 pts)

Critère	Attentes
Répartition de la parole	Tous les membres participent de manière équitable, temps de parole équilibré
Participation aux démonstrations	Chaque membre montre sa maîtrise d'au moins un point technique ou manip pratique
Réactivité aux questions	Les étudiants répondent aux questions du jury, se soutiennent mutuellement, savent compléter ou corriger un collègue si nécessaire
Travail en groupe	Cohérence du discours, groupe coordonné, capacité à expliquer l'ensemble du projet sans contradiction

2. Organisation de la soutenance

 **Durée totale : 30 – 35 minutes**

◆ **Présentation : 15 à 20 min**

- 3 à 4 intervenants selon votre groupe de 3 ou 4 (répartition équitable)
- Support visuel recommandé (schéma + checklist)

Structure attendue :

1. Contexte & objectifs
2. Architecture réseau
3. Sécurité & défense en profondeur
4. Haute dispo & démonstration prévue

◆ **Questions & manipulations : 15 à 20 min**

3. Points techniques à vérifier en direct

- Adressage IP de chaque réseau
- Nomenclature claire

- Interfaces pfSense par zone
- Règles firewall effectives
- Table NAT
- Écoute des services (ss/netstat)
- Accès BDD depuis une autre zone (doit échouer)
- Accès admin depuis DMZ (doit échouer)

? 4. Questions potentielles à poser

Architecture / réseau

- Pourquoi séparer frontend et data ?
- Que se passerait-il si le serveur web était compromis ?
- Pourquoi pfSense comme point central ?
- Quelle différence entre DMZ et frontend ?

Sécurité

- Quelles mesures CIS avez-vous jugées prioritaires ?
- Qu'est-ce que vous n'avez **pas** sécurisé et pourquoi ?
- Quels risques restent présents ?

Haute disponibilité

- Que devient la VIP si HAProxy 1 tombe ?
- Est-ce une vraie HA ou seulement une tolérance de panne ?
- Quels SPOF restent présents ?

Administration

- Pourquoi isoler le réseau admin ?
- Comment limiter les risques liés à SSH ?

5. Actions pratiques possibles pendant la soutenance

HA / Résilience

-  Éteindre HAProxy 1 → vérifier continuité du service
-  Couper un backend → observer comportement HAProxy

Sécurité réseau

-  Tentative d'accès BDD depuis DMZ
-  Tentative SSH depuis un mauvais réseau

Firewall

-  Demander l'affichage et l'explication d'une règle précise
-  Supprimer temporairement une règle et observer l'impact

6. Critères transverses (appréciation globale)

- ✓ Compréhension réelle (pas seulement exécution)
- ✓ Capacité à justifier les choix
- ✓ Discours technique maîtrisé
- ✓ Cohérence globale
- ✓ Travail de groupe visible

7. BONUS

Des points bonus seront attribués pour les implémentations suivantes

- Certificat SSL + redirection HTTP VERS HTTPS
- Redondance de la BDD
- Redondance du Firewall
- Chiffrement de la BDD
- Chiffrement des mots de passe en clair